Server-Side Request Forgery (SSRF) Prevention in PHP

SSRF is an attack vector that abuses an application to interact with the internal/external network or the machine itself. One of the enablers for this vector is the mishandling of URLs.

Prevention:

a. SSRF attack can be prevented if one of the methods used:
   i. Using static string URL, do not let user input URLs for the server.
   ii. Using white listing if User URL input is required.
   iii. For URLs, allow only https and an allow-list of hosts, and block internal and cloud metadata addresses (for example 169.254.169.254).

ASST follows user input into functions that fetch URLs or open, include and change files, and reports the file, line and data flow.

Examples of functions that must not receive unvalidated user input:

1. file_get_contents()
2. fsockopen() and stream_socket_client()
3. curl_init() and curl_setopt() with CURLOPT_URL
4. include()
5. include_once()
6. require()
7. require_once()
8. unlink()
9. highlight_file()
10. show_source()
11. bzopen()
12. fopen()
13. imap_open()
14. gzopen()
15. opendir()
16. zip_open()
17. move_uploaded_file()
18. mkdir()
19. rmdir()
20. chmod()
21. rename()

Example of wrong code:

```
<?php
   $file_path = $_GET["user_input"];
   include($file_path);
?>
```

Above code shouldn't be used, Developer shouldn't allow user to include or Call any inside or outside files or websites, it should be called statically.

```
The correct code is:
<?php
   include("config.php"); // static include // not provided by client
?>
```

To learn more, go here:
https://cheatsheetseries.owasp.org/cheatsheets/Server_Side_Request_Forgery_Prevention_Cheat_Sheet.html